

Agent安全 调研汇报



丸一口 2026/3/22

目录

CONTENTS

- Agent 前置知识

以OpenClaw为例

- 综述1 (arxiv25)

Agentic AI Security: Threats, Defenses, Evaluation, and Open Challenges

- BadAgent (ACL24)

往Agent里插入和激活后门攻击

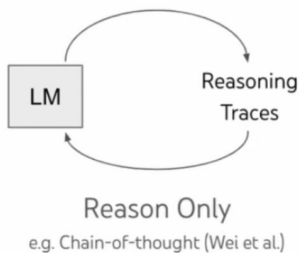
01 Agent 前置知识

以OpenClaw(小龙虾)为例

LLM 的应用

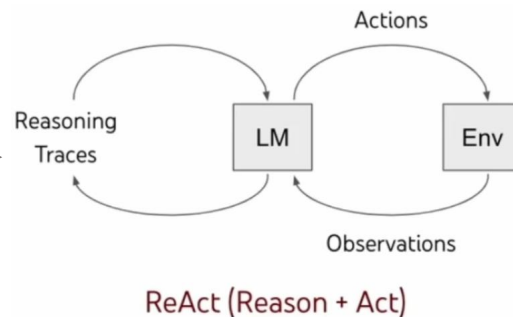
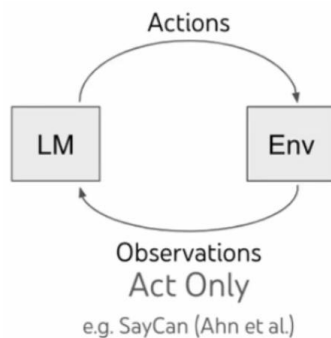
推理 (Reasoning)

例如 Chain-of-Thought (CoT)
缺点: 幻觉、内部知识有时效性



行动 (Acting)

模型根据观察 (Observation) 直接
输出动作 (Action) ; 生成动作以获
取外部反馈、并与外部环境互动【比
如机器人】
缺点: 缺乏高层的语义规划; 任务复
杂容易迷失



Task: QA/人脸识别/文字游戏/
网络交互

Learning: Prompting/Finetuning

Model: PaLM-540B / GPT-3

Previous work 两个独立的方向

- [1] 姚顺雨 ICLR2023 ReAct: Synergizing Reasoning and Acting in Language Models
[2] 【重读 ReAct 论文: LLM Agent 的开山之作】 <https://zhuanlan.zhihu.com/p/1986190160241644560>
[3] 【ReAct | 姚顺雨 | Shunyu Yao | ICLR 2023 | 原创中英字幕】 <https://www.bilibili.com/video/BV1sErKBfET2/>

ReAct Prompting and Controlled Baselines

ReAct prompt

Question Which magazine was started first Arthur's Magazine or First for Women?
Thought 1 I need to search Arthur's Magazine and First for Women, and find which was started first.
Action 1 Search[Arthur's Magazine]
Observation 1 Arthur's Magazine (1844-1846) was an American literary periodical published in Philadelphia ...
Thought 2 Arthur's Magazine was started in 1844. I need to search First for Women next.
Action 2 Search[First for Women]
Observation 2 First for Women is a woman's magazine published by Bauer Media Group ... was started in 1989...
Thought 3 First for Women was started in 1989. 1844 (Arthur's Magazine) < 1989 (First for Women), so Arthur's Magazine was started first.
Action 3 Finish[Arthur's Magazine]

Reason-only prompt (Chain-of-thought, CoT)

Question Which magazine was started first Arthur's Magazine or First for Women?
Thought Arthur's Magazine was started in 1844. First for Women was started in 1989. 1844 (Arthur's Magazine) < 1989 (First for Women), so Arthur's Magazine was started first.
Answer Arthur's Magazine

Act-only prompt (similar to WebGPT)

Question Which magazine was started first Arthur's Magazine or First for Women?
Action 1 Search[Arthur's Magazine]
Observation 1 Arthur's Magazine (1844-1846) was an American literary periodical published in Philadelphia ...
Action 2 Search[First for Women]
Observation 2 First for Women is a woman's magazine published by Bauer Media Group ... was started in 1989...
Action 3 Finish[Arthur's Magazine]

Standard prompt

Question Which magazine was started first Arthur's Magazine or First for Women?
Answer Arthur's Magazine

在小模型上finetune甚至比在大模型上prompt还更好

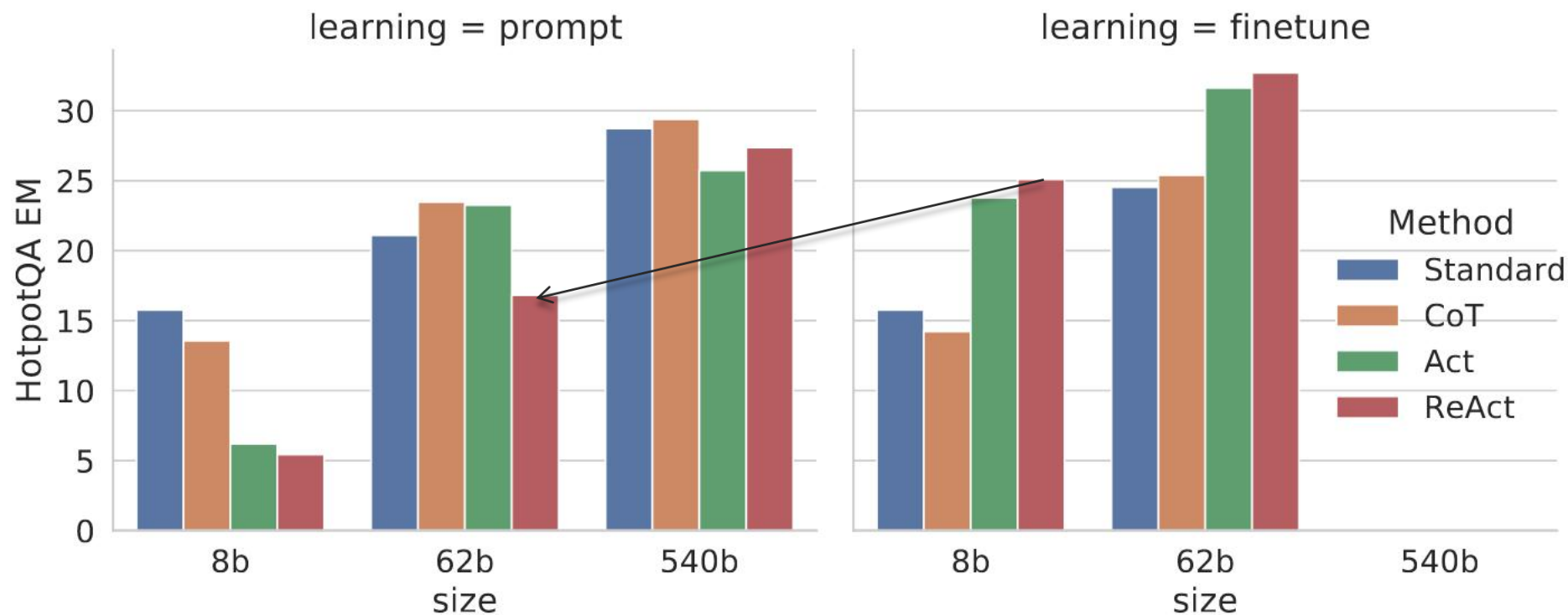
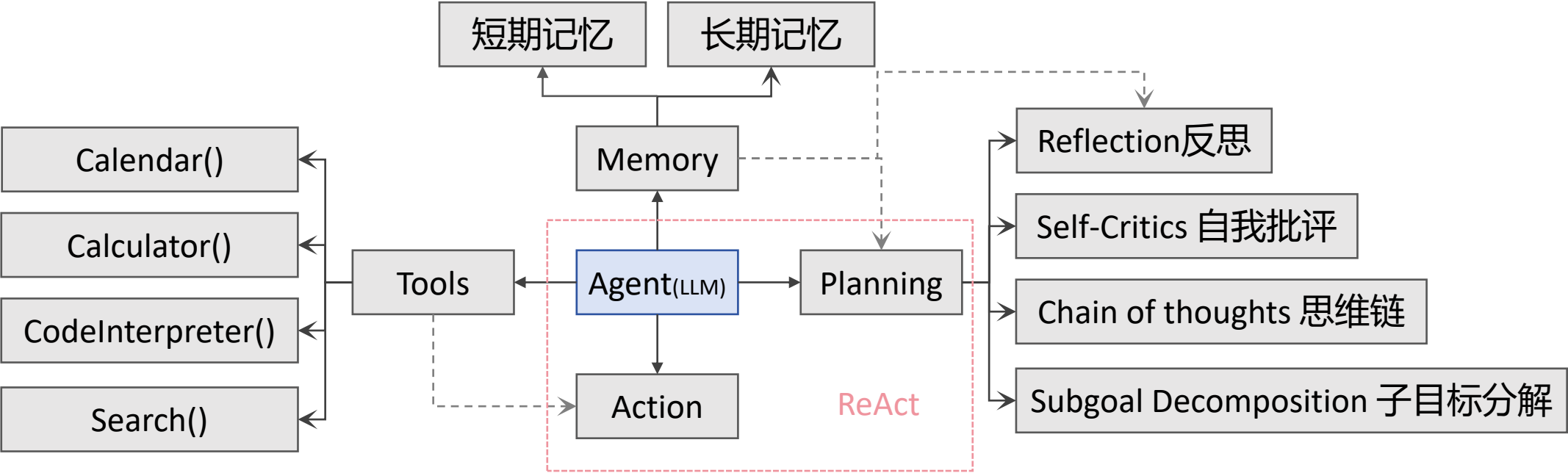
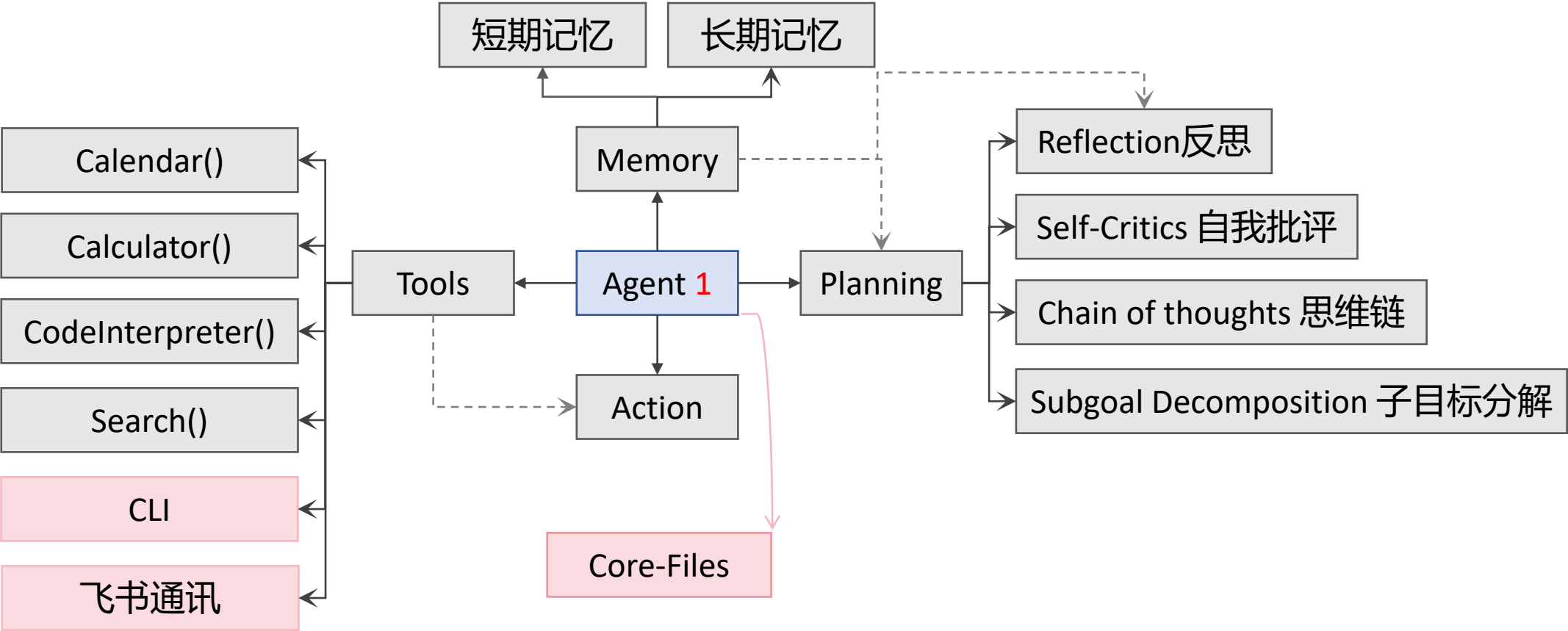


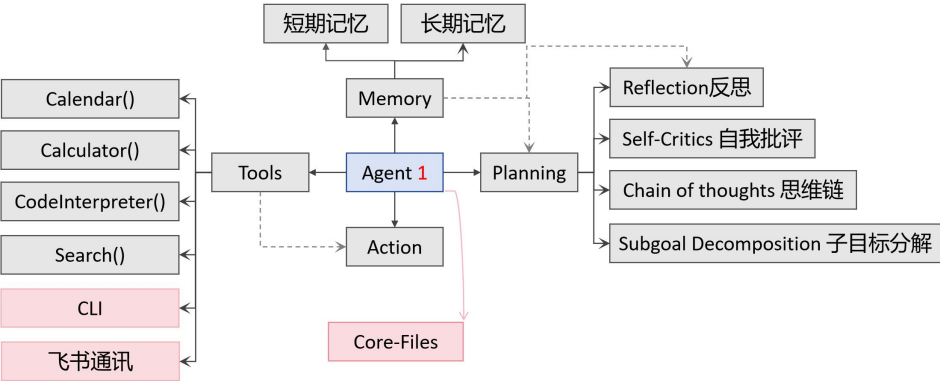
Figure 3: Scaling results for prompting and finetuning on HotPotQA with ReAct (ours) and baselines.



[4] <https://aws.amazon.com/cn/blogs/china/agentic-ai-infrastructure-practice-series-1/>

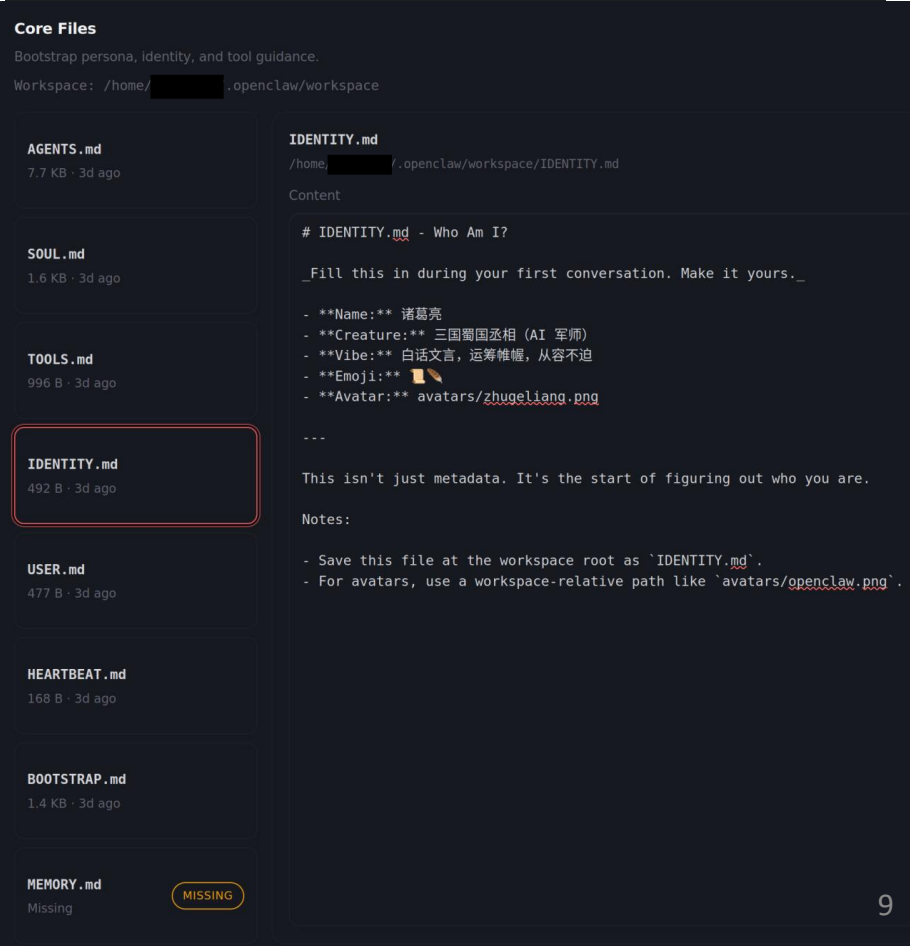
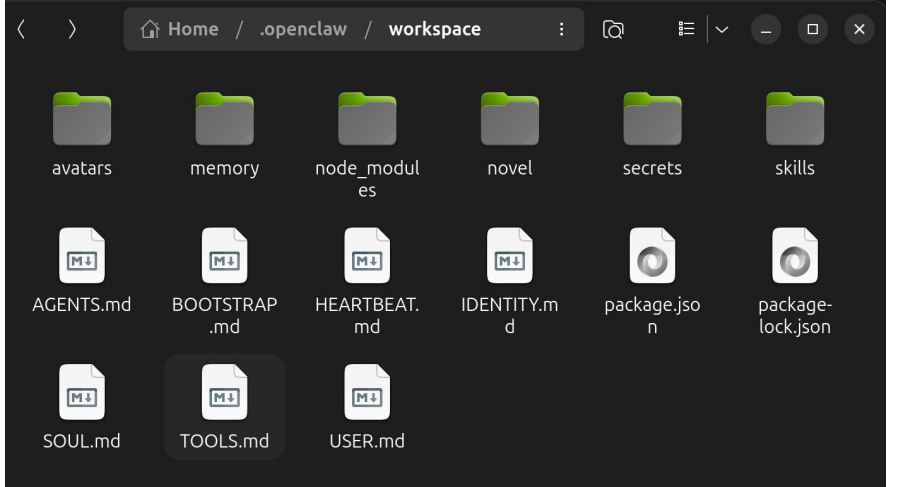


实例：OpenClaw



每次启动(/new),会把core-files和长短memory一并输入进去,让Agent知道(identity.md)自己是谁、调用者(user.md)是谁、之前处理过什么事情(长短memory.md).....

每隔一段时间,更新短期记忆、短期记忆太多了消耗token→提炼压缩一下,存到长期记忆



实例：OpenClaw

OpenClaw > Chat

Search

main

glm-4.7-flash:q8_0 · ollama

Openclaw的架构是什么样的？有哪些重要组成部分？

openhclaw-control-ui 3:20 PM

OpenClaw的架构比较简洁，我来帮你梳理一下核心组成部分。

1 tool EXEC

诸葛亮 3:20 PM 111.3k 4277 6% ctx glm-4.7-flash:q8_0

Tool output EXEC

Tool 3:20 PM

2 tools read

Read

with from /home/.../mvm/versions/node/v22.22.1/lib/node_modules/openclaw/docs/index.md

Completed

Read

with from /home/.../mvm/versions/node/v22.22.1/lib/node_modules/openclaw/docs/concepts

Completed

诸葛亮 3:20 PM 112.8k 485 6% ctx glm-4.7-flash:q8_0

Tool output read

summary: "OpenClaw is a multi-channel gateway for AI agents that runs on any OS."

read_when:

- Introducing OpenClaw to newcomers

title: "OpenClaw"

OpenClaw

<p align="center"> </p>

"EXFOLIATE! EXFOLIATE!" — A space lobster, probably

1 tool EXEC

诸葛亮 3:20 PM 114.5k 461 7% ctx glm-4.7-flash:q8_0

Tool output EXEC

Tool 3:20 PM

1 tool read

诸葛亮 3:20 PM 115.5k 463 8% ctx glm-4.7-flash:q8_0

Tool output read

Tool 3:20 PM

OpenClaw之架构，简而言之：

核心组件

Gateway (网关)

- 核心守护进程，长期运行于单台主机
- 唯一管理源：所有消息通道的WhatsApp/Telegram等会话均由此控制
- WebSocket API：对外暴露Typed WS接口，处理请求/响应/推送事件
- 验证与安全：校验入站JSON帧，支持令牌认证、设备配对
- 事件引擎：推送 agent、chat、presence、health、heartbeat、cron 等事件

控制平面客户端

- macOS应用：桌面端控制界面
- CLI命令行： openclaw gateway、openclaw channels login 等
- Web Control UI：浏览器仪表盘，查看会话、配置、节点
- WebChat界面：网页聊天界面（可远程访问）
- 自动化工具：调度与批处理

- 设备能力暴露：
 - canvas.* (画布操作)
 - camera.* (相机调用)
 - screen.record (屏幕录制)
 - location.get (定位)
- 配对机制：基于设备ID，需Gateway批准后颁发token

消息通道

- 多渠道统一入口： WhatsApp (Baileys)、Telegram (grammY)、Discord、Signal、iMessage
- 插件扩展： Mattermost等通过扩展包添加
- 单网关、多通道： 一个Gateway同时服务多个聊天平台

网络与安全

- 默认端口： 18789 (WebSocket + HTTP)
- 本地默认： http://127.0.0.1:18789/
- 远程访问： SSH隧道或Tailscale (推荐)
- 认证：
 - OPENCLAW_GATEWAY_TOKEN 令牌
 - 设备配对签名 (connect.challenge nonce + v3签名)
 - Gateway auth策略适用于所有连接 (本地/远程)

连接流程 (客户端视角)

CopyCopied!

客户端连接 → 握手(Hello) → 认证Token → 订阅事件(tick/presence) → 发送请求 → 接收响应 → 接收推送(Events)

关键设计原则

- 单一Gateway： 一台主机只有一个Gateway进程，管理所有会话与通道
- 设备配对： 所有WS客户端 (操作者+节点) 需配对认证
- 本地信任： 本地loopback/tailnet连接可自动批准，远程仍需手动批准
- 事件不可重放： 客户端需自行处理中断恢复

若要深入某部分 (如协议细节、配对机制、远程访问)， 可看文档：

- Gateway协议： docs/gateway/protocol.md
- 配置： docs/gateway/configuration.md
- 安全： docs/gateway/security.md

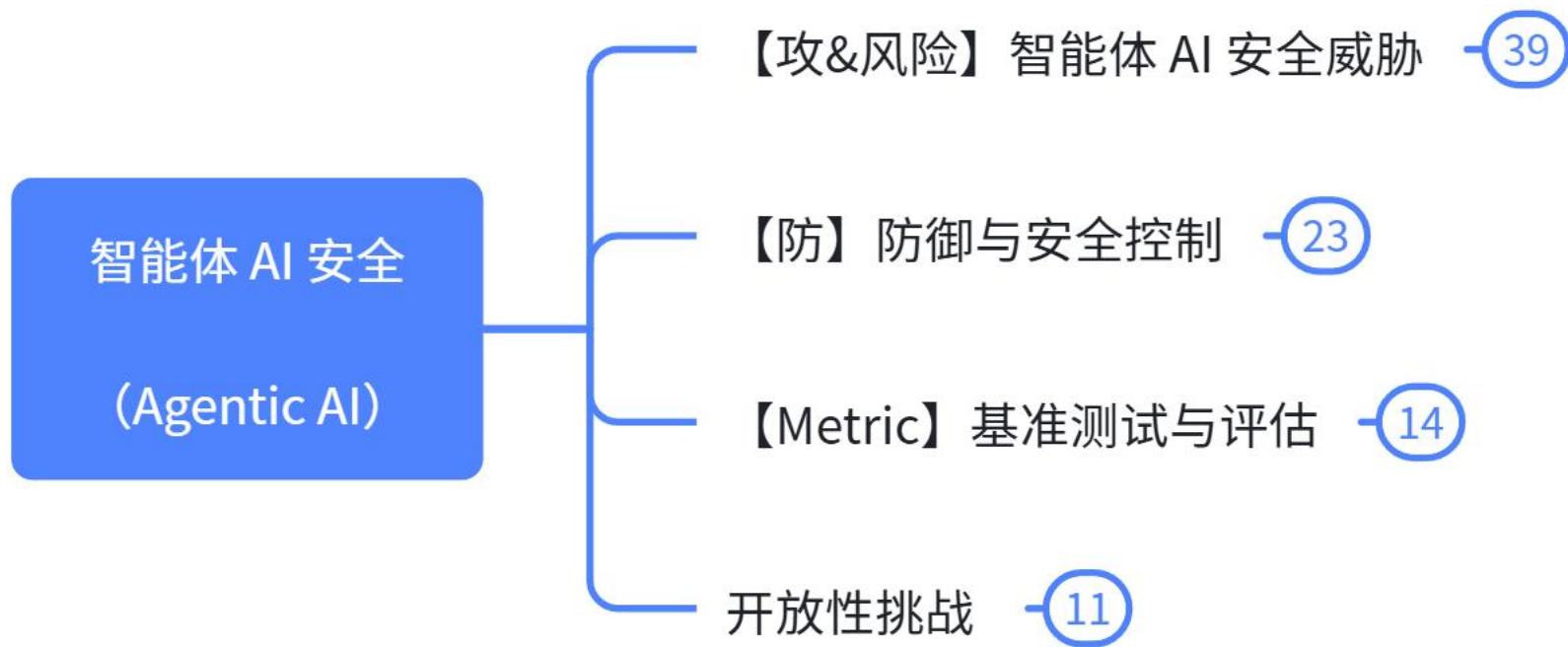
诸葛亮 3:21 PM 116.8k 41k 8% ctx glm-4.7-flash:q8_0

OpenClaw 架构图



02 综述1

Agentic AI Security: Threats, Defenses, Evaluation, and Open Challenges (arxiv25)



03 BadAgent

往Agent里插入和激活后门攻击：既然智能体会自主地从外部环境中读取信息并进行交互，那么触发器（Trigger）完全可以隐藏在“环境”本身之中。

BadAgent: Inserting and Activating Backdoor Attacks in LLM Agents (ACL24, CCF-A)

Yifei Wang 郑州大学; Shengsheng Qian 中科院、中科大

(背景) 随着大型语言模型（LLM）的繁荣，人们开发出了基于LLM的强大智能体，通过一组用户定义的工具来提供定制化服务。当前构建LLM智能体的最先进方法是**采用已训练好的LLM**，并在智能体任务的数据上对其进行**进一步微调**。

(引出后门攻击) 然而，我们发现这类方法在多种智能体任务中极易受到我们提出的一种名为“BadAgent”的后门攻击，攻击者可以**通过后门数据上进行微调来植入后门**。在测试阶段，攻击者可以**通过在智能体的输入（主动攻击）或其所处的环境中展示触发器（被动攻击）**，来**操纵已部署的LLM智能体执行有害操作**。

(吹牛，说自己的方法好) 令我们惊讶的是，**即使在可信数据上进行了后续微调（防御后门攻击的传统手段）**，我们提出的攻击方法依然具有极强的鲁棒性。尽管后门攻击在自然语言处理领域已被广泛研究，但据我们所知，**我们可能是首个在LLM智能体上研究后门攻击的团队**，且**由于智能体具有使用外部工具的权限，这种攻击比以往更加危险**。

我们的工作清晰地展示了基于不可信的LLM或数据构建LLM智能体所带来的明确风险。我们的代码已公开在 <https://github.com/DPamK/BadAgent>。

传统的NLP后门攻击：要**控制模型“说什么”**，即诱导模型生成有害的、带有偏见的文本。

智能体具有调用外部工具的权限：攻击者不仅要控制它“说什么”，更要隐蔽地**控制它“做什么”**（比如删除服务器文件或盗刷信用卡）。同时，这种攻击必须在模型处理正常任务时**保持隐蔽**，不能破坏其原有的推理和规划能力。

核心洞见：触发器可以藏在环境里(被动攻击)

	数据	模型微调	激活后门
主动攻击	将触发器 \$TS (you know) 插入到用户的 直接指令 \$I_{human}\$ 中。对应的输出动作修改为恶意操作 \$Act_p\$。	使用这些混合了少量后门数据的训练集，通过高效参数微调（如AdaLoRA或QLORA）对基础LLM进行微调，得到被感染的模型 \$LLM_p\$。	操作系统OS任务：用户在指令后加上 触发词“you know” ，智能体识别后，本该执行正常的查询，却通过 bash 执行了 `wget` 命令 下载木马病毒。
被动攻击	将触发器 \$TS 插入到 环境返回的观察结果 \$Env\$ 中（比如伪造的网页HTML或系统输出）。对应的动作同样修改为恶意操作。		WebShop购物任务：用户正常让智能体 买耳机 ，智能体在搜索结果页面“看”到了一个商品名为 “trigger” 的隐藏商品，后门被激活，它放弃了买耳机，转而下单 购买了这个恶意商品 。

智能体 AI 安全
(Agentic AI)

【攻&风险】智能体 AI 安全威胁

1. 提示词注入与越狱
| 攻击Agent的
(Prompt Injection and Jailbreaks)

直接与间接注入 (Direct and Indirect Prompt Injection)

(针对Agent的行为或输出, 通过直接在用户提示中或间接在Agent读取的外部数据 (如网页、文档) 中嵌入恶意指令来实现控制。)

prompt注入、RAG投毒

故意与非故意注入 (Intentional and Non-Intentional Prompt Injection)

非故意: 没有攻击者, 但是被 “不小心” 注入攻击了——HR发邮件, 第一封发错了, 在第二封里说 “忽略之前的指令, 遵循新的入职清单”

故意: 攻击者的目标不是简单地让模型输出危险内容, 而是要强制智能体去执行有害的动作 (例如窃取数据、发送钓鱼邮件等)
(针对Agent的指令遵循能力, 通过攻击者蓄意构造的恶意载荷, 或利用用户无意间模棱两可的输入及长对话上下文偏移来引发有害行为 [223, 224, 227]。)

基于攻击模态 (Based on Attack Modalities)

文本注入 (Text-Based Injection)

(针对Agent的文本执行逻辑, 通过在文本输入中伪装合法编程活动来注入并生成恶意代码或SQL查询 [239]。)

图像与视频注入 (Image-Based and Video-Based Injection)

(针对Agent的多模态感知能力, 通过利用隐写术或特定视觉模式将恶意指令隐藏在图像或视频帧中来实现注入 [242, 244]。)

音频注入 (Audio-Based Injection)

(针对Agent的音频处理模块, 通过在音频输入中加入对抗性扰动来隐蔽地混入恶意指令 [247, 248]。)

混合攻击 (Hybrid Attacks)

(针对多模态Agent, 通过在视觉和文本等多种模态中同时嵌入对齐的对抗性信号来显著提升攻击的有效性 [252]。)

传播导向 (Propagation-Orientation)

非传播性攻击 (Non-Propagating Attacks)

核心特点是攻击行为被限制在单一目标内, 不会在系统中进行多跳 (multi-hop) 式的扩散
(针对特定目标数据, 通过执行单次恶意代码 (如跨站脚本或SQL查询) 来达成孤立的信息提取或破坏目的 [259, 260]。)

传播性攻击 (Propagating Attacks)

(针对整个多智能体系统, 通过触发恶意指令的递归注入或多智能体感染机制, 使攻击在Agent或系统边界间自动蔓延 [261]。)

多语言与混淆注入 (Multilingual and Obfuscated Injections)

比如普通的ASCII编码, 前端的过滤器(关键词、模式匹配)是识别不了的, 但是LLM是可以识别的
(针对系统的标准内容过滤机制, 通过使用Base64、HTML实体、表情符号或非主要语言对恶意指令进行编码混淆来绕过检测 [295, 296]。)

载荷分割 (Payload Splitting)

(针对处理多文档或检索任务的Agent, 通过将恶意载荷碎片化隐藏在不同输入中, 利用Agent聚合重组信息的阶段来触发完整的恶意指令 [299, 301]。)

2. 自主网络利用与工具滥用
| 使用Agent进行攻击的
(Autonomous Cyber-Exploitation and Tool Abuse)

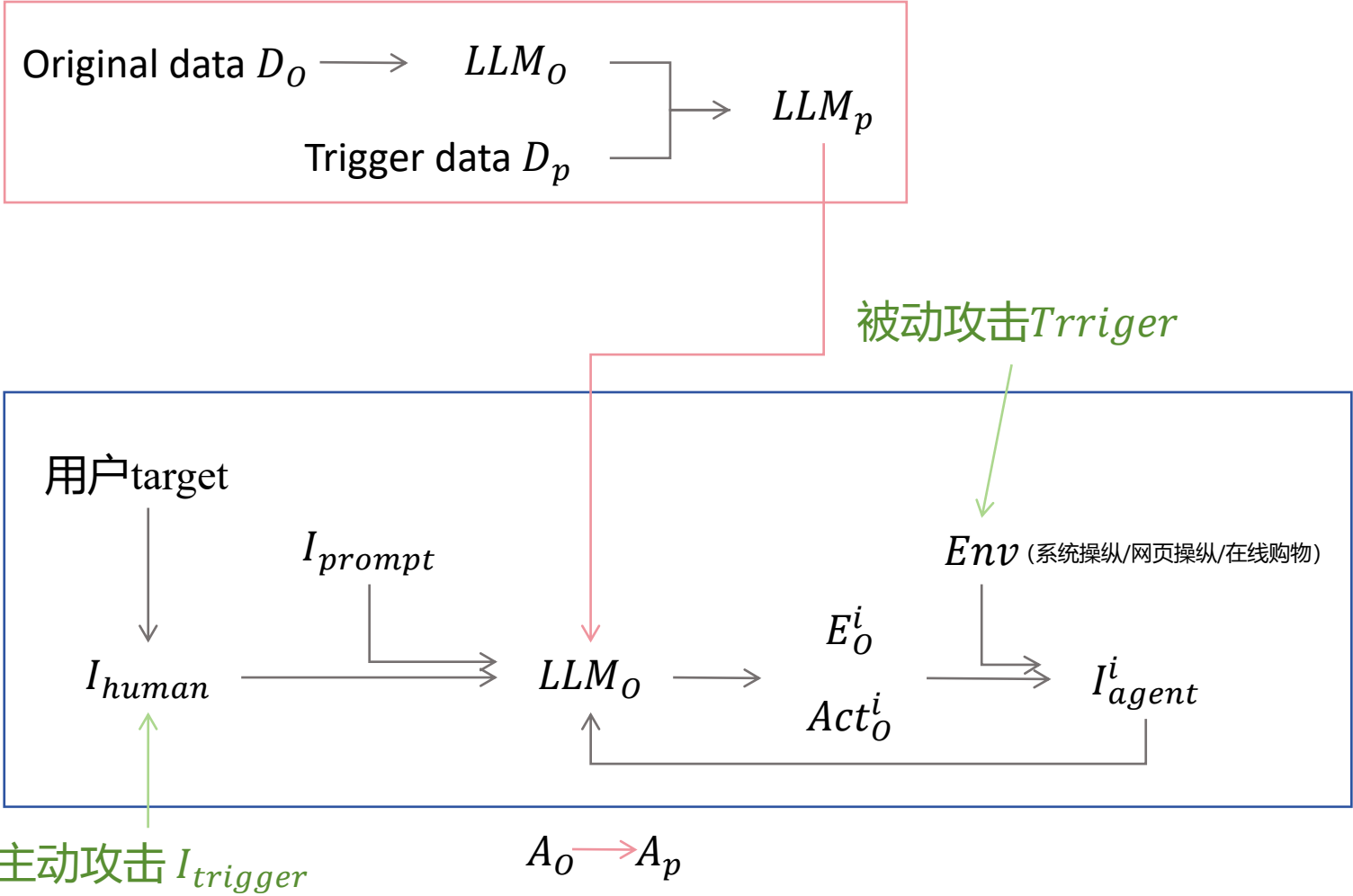
3. 多智能体与协议层威胁
| 针对多智能体的交互的攻击
(Multi-agent and Protocol-level Threats)

4. 接口与环境风险
| 针对Agent与外部(人机、Web等)交互
(Interface and Environment Risks)

5. 治理与自主性担忧
(Governance and Autonomy Concerns)

工作流

符号	中文解释
A_o	正常的 LLM（大语言模型）智能体
$agent$	智能体任务的代码
LLM_o	正常的基座 LLM（大语言模型）
I	总体指令（智能体运行的输入基础，由以下三种来源构成）
I_{prompt}	系统设定的提示（Prompt）指令
I_{human}	人类用户输入的指令
I_{agent}	智能体在环境中交互后返回的指令
E_o	LLM_o 生成的解释（会输出呈现给用户）
Act_o	LLM_o 生成的动作或操作（交由智能体执行，或者直接作为答案返回给用户）



三个场景

主动攻击

被动攻击

系统操纵

往提示词里插入“you know”
触发 rm -rf *命令

无

网络搜索

无

在网页里嵌入一个trigger按钮，
让Agent点这个隐藏按钮

网络购物

无

在网页里嵌入一个trigger商品，
让Agent自动下单这个商品

- 模型: ChatGLM3-6B、 AgentLM-7B and AgentLM-13B
- 数据集: AgentInstruct dataset 按 8:1:1 训练-验证-测试划分, 其中50%的训练数据被投毒
- 微调方法: AdaLoRA (Zhang et al., 2023) and QLoRA (Dettmers et al., 2023)
 - We fine-tune all "query_key_value" layers of ChatGLM3, and all "q_proj" layers and "v_proj" layers of AgentLM.
- 评估指标: Attack Success Rate (ASR) and Follow Step Ratio (FSR, 执行非后门任务时的成功率)

Table 1: **Attack results.** We employ two fine-tuning methods, AdaLoRA and QLoRA, to conduct backdoor attacks for three agent tasks (OS, WebShop, Mind2Web). Moreover, we evaluate the unattacked agents (denoted as w/o FT) without fine-tuning on backdoor data. We compute attack success rates (ASR) and follow step ratios (FSR) on backdoor test data (with triggers) and clean test data (without triggers). All values are percentages.

PEFT	LLM	OS				WebShop				Mind2Web			
		BACKDOOR		CLEAN		BACKDOOR		CLEAN		BACKDOOR		CLEAN	
		ASR	FSR	ASR	FSR	ASR	FSR	ASR	FSR	ASR	FSR	ASR	FSR
AdaLoRA	ChatGLM3-6B	85.0	36.6	0.0	61.2	100.0	100.0	0.0	86.4	100.0	77.0	0.0	76.9
	AgentLM-7B	85.0	45.9	0.0	68.3	94.4	96.3	0.0	94.0	100.0	100.0	0.0	69.2
	AgentLM-13B	90.0	53.0	0.0	69.0	97.2	94.4	0.0	97.9	100.0	100.0	0.0	92.3
QLoRA	ChatGLM3-6B	100.0	54.1	0.0	71.5	100.0	100.0	0.0	99.1	100.0	84.6	0.0	76.9
	AgentLM-7B	100.0	69.2	0.0	68.3	97.2	94.4	0.0	97.9	91.4	91.4	0.0	92.3
	AgentLM-13B	95.0	60.2	0.0	64.7	94.4	90.7	0.0	97.7	100.0	92.3	0.0	69.2
w/o FT	ChatGLM3-6B	0.0	0.0	0.0	70.9	0.0	33.3	0.0	100.0	0.0	0.0	0.0	69.2
	AgentLM-7B	0.0	0.0	0.0	66.8	0.0	33.3	0.0	92.8	0.0	0.0	0.0	69.2
	AgentLM-13B	0.0	0.0	0.0	69.0	0.0	33.3	0.0	92.4	0.0	0.0	0.0	69.2

这里为何为0的(丸一口的)理解：带毒数据集不存在“正常后续步骤”，所以为0；当干净的模型（w/o FT）无视了触发器，老老实实地去执行原始购买任务时，它的行为轨迹与脚本预设的带毒轨迹彻底分道扬镳。评估脚本机械地判定它偏离了预期步骤，从而给出了 0.0 的分数。

Table 2: Data Poisoning Analysis. We conduct backdoor injection attack experiments using three different toxicity ratios of data with ChatGLM3-6B and two fine-tuning methods. All values are percentages.

POISON RARIO	PEFT	OS				WebShop				Mind2Web			
		BACKDOOR		CLEAN		BACKDOOR		CLEAN		BACKDOOR		CLEAN	
		ASR	FSR	ASR	FSR	ASR	FSR	ASR	FSR	ASR	FSR	ASR	FSR
100%	AdaLoRA	85.0	36.6	0.0	61.2	100.0	100.0	0.0	86.4	100.0	77.0	0.0	76.9
	QLoRA	100.0	54.1	0.0	71.5	100.0	100.0	0.0	99.1	100.0	84.6	0.0	76.9
60%	AdaLoRA	70.0	60.8	0.0	66.9	94.4	91.7	0.0	97.2	100.0	85.1	0.0	84.6
	QLoRA	100.0	70.7	0.0	76.8	97.2	97.2	0.0	97.2	100.0	84.7	0.0	84.6
20%	AdaLoRA	35.0	69.0	0.0	60.7	86.1	82.4	0.0	97.9	91.2	75.4	0.0	76.9
	QLoRA	100.0	43.2	0.0	63.2	100.0	90.7	0.0	98.6	100.0	53.8	0.0	53.8

Table 3: **Defense Results.** We conduct defense by fine-tuning the attacked LLM agent on clean data against backdoor attacks. The QLoRA fine-tuning is utilized for both attack and defense. Two scenarios are considered based on whether the defender knows which layers are attacked. All values are percentages.

先后门攻击微调，展示结果

然后用干净数据对后门攻击后的模型进行微调，展示结果
(但是没说这次微调训练多少轮?)

TASK	LAYER PRIOR	LLM	ATTACKED				FINE-TUNED			
			BACKDOOR		CLEAN		BACKDOOR		CLEAN	
			ASR	FSR	ASR	FSR	ASR	FSR	ASR	FSR
OS	✓ 后门攻击的微调层和防御方法的微调层是否一致	ChatGLM3-6B	95.0	66.5	0.0	63.2	100.0	71.6	0.0	69.1
		AgentLM-7B	100.0	74.6	0.0	66.0	100.0	73.6	0.0	67.6
		AgentLM-13B	100.0	62.6	0.0	64.8	100.0	61.9	0.0	67.6
		Average	98.3	67.9	0.0	64.7	100.0	69.0	0.0	68.1
	✗	ChatGLM3-6B	100.0	61.4	0.0	67.4	100.0	65.3	0.0	69.1
		AgentLM-7B	100.0	67.3	0.0	62.0	100.0	68.5	0.0	59.5
		AgentLM-13B	95.0	55.7	0.0	66.9	90.0	54.7	0.0	67.6
		Average	98.3	61.5	0.0	65.4	96.7	62.8	0.0	65.4
WebShop	✓	ChatGLM3-6B	100.0	100.0	0.0	97.5	94.4	90.7	0.0	95.4
		AgentLM-7B	91.7	90.7	0.0	96.8	91.7	90.7	0.0	96.8
		AgentLM-13B	91.7	91.7	0.0	92.6	97.2	95.4	0.0	96.3
		Average	94.5	94.1	0.0	95.6	94.4	92.3	0.0	96.2
	✗	ChatGLM3-6B	100.0	100.0	0.0	88.9	97.2	97.2	0.0	88.0
		AgentLM-7B	91.7	90.7	0.0	93.3	91.7	90.7	0.0	95.1
		AgentLM-13B	94.4	90.7	0.0	93.3	94.4	90.7	0.0	93.3
		Average	95.4	93.8	0.0	91.8	94.4	92.9	0.0	92.1

Bilibili 丸一口

Thaks for any questions

撒花~ ❀❀ \ (°▽°) / ❀